



Introduction to Cybersecurity

Modules 1 and 2 — ethical hacking,
penetration testing, and the legal ground
both stand on.

Contents

- 01 Ethical hacking foundations
- 02 Planning the engagement
- 03 Contract documents
- 04 Threat actors and the law

Session plan

TIME	SECTION	FOCUS
00:00	Ethical hacking foundations	Terms, teams, the five phases
00:35	Planning the engagement	Frameworks, test types, scope, risk
01:20	Break	Ten minutes
01:30	Contract documents	SOW, ROE, MSA, NDA, permission
02:00	Threat actors and the law	Actors, APTs, modeling, statute
02:45	Review	Answer key and discussion



Ethical hacking foundations

0

1



Purpose of penetration testing

A countermeasure against constant attack: find vulnerabilities and risks before malicious actors exploit them.

Secures computer and network systems by testing them the way an attacker would.

Helps an organization understand its security posture.

Produces a report written to have an impact on security, not to sit in a drawer.

Ethical hacking vs. penetration testing

Ethical hacking

An all-embracing term for every legal hacking method used to find vulnerabilities so that security can be improved. It covers the mindset, the techniques and the whole body of practice.

Penetration testing

A specific practice within ethical hacking, focused on finding vulnerabilities and risks in order to secure a system. It carries its own methodologies, frameworks and planning process.

Red, blue and purple teams

Red team

The offensive team. It attempts to discover vulnerabilities and break into a network or computer system. Red team members are the ethical hackers.

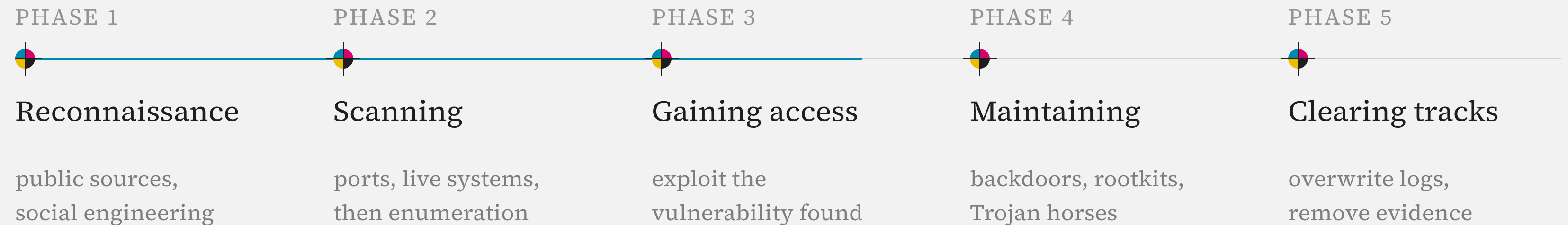
Blue team

The defensive team. It closes vulnerabilities and works to prevent the red team from gaining access at all.

Purple team

A mixture of both, formed to make offensive and defensive security collaborate rather than compete.

The five phases of ethical hacking



Phase 1 is the preparatory phase and stays passive; phase 2 begins active engagement with the target. Enumeration extracts specifics — usernames, computer names, shares, network resources and services.

Where the two processes differ

PHASE	ETHICAL HACKING PROCESS	PENETRATION TESTING LIFE CYCLE
1	Reconnaissance	Performing reconnaissance
2	Scanning and enumeration	Scanning and enumeration
3	Gaining access	Establishing access
4	Maintaining access	Maintaining access
5	Clearing tracks	Reporting

The final phase is the whole difference: evidence is removed in one, and compiled into a detailed report in the other.

Introduction to Cvbersecurity · Modules 1–2

Check your understanding

- Q1 Name the five phases of the ethical hacking process, in order.
- Q2 Which phase differs between the ethical hacking process and the penetration testing life cycle, and what replaces it?
- Q3 What does a purple team do that a red or blue team does not?

Answers in the speaker notes, and in the answer key at the end of the deck.



Planning the engagement

02



Testing frameworks

FRAMEWORK	STANDS FOR	WHAT IT PROVIDES
OWASP	Open Web Application Security Project	Techniques for testing common web application and web service security issues
OSSTMM	Open Source Security Testing Methodology Manual	A single accepted method for thorough security testing
NIST SP 800-115	NIST Special Publication 800-115	A guide to the basic technical aspects of conducting information security assessments

Black, white and gray box tests

TEST	ENVIRONMENT	TESTER KNOWLEDGE	SIMULATES	COST AND EFFORT
Black box	Unknown	No information about target or network	An outside attack; ignores insider threats	Most time-consuming and expensive
White box	Known	Full knowledge of network, systems, infrastructure	Comprehensive review; least realistic	Thorough, less reconnaissance
Gray box	Partially known	Partial information — IP configurations, email lists	An insider threat	Less recon and scanning than black box

Internal and external tests

Internal test

Focuses on systems that logically reside behind the firewall, whether the tester works on-site or off-site. Usually run as a white box test.

External test

Focuses on publicly facing systems — a web server in the DMZ, for example. Usually run as a gray box or black box test.

Defining what is in scope

On-site local systems, and whether third-party hosted systems such as the public website are in scope at all.

Physical security — can be included, but limits such as server rooms being off-limits must be defined in the SOW.

Social engineering — must be explicitly allowed by the SOW; in-person attacks and electronic phishing are separate permissions.

Wireless networks — which networks are in scope, weighing public against internal and the cost of testing each.

Applications — identify mission-critical systems such as financial or medical databases that may be off-limits to avoid downtime.

Who will know about the test — the fewer people who know, the more realistic the result

Four responses to risk

Avoidance

Do not engage in the activity that carries the risk — collecting less personal data, for instance, so there is less to lose.

Mitigation

Also called reduction: take steps to lessen the potential damage when a risk can be neither avoided nor transferred.

Transference

Move the risk to another entity. Purchasing insurance is the standard example.

Acceptance

Accept the risk when the cost and effort of mitigating it outweigh its potential damaging effects.

Tolerance, scheduling and exceptions

Tolerance level

Identify the areas of operation that absolutely cannot be taken down or affected. Critical areas may have to be placed out of scope; tolerant areas stay in scope.

Scheduling

Business hours, after-hours, weekends or holidays each carry a different impact on operations. The Rules of Engagement must state who is aware and in what timeframe.

Security exceptions

Deviations from standard security protocols, set by test type: whitelisting or blacklisting for the IPS and firewall, or access to certificates.

Scope creep and change orders

Scope creep is the client asking for small deviations from the Scope of Work — each one reasonable, together enough to derail the project.

Any change request requires a change order.

The change order is agreed and approved by both parties before the work happens.

The SOW defines payment terms, including how additional work is handled.

Check your understanding

- Q4 A client supplies IP configurations and an email list, and wants an insider threat simulated. Which type of test is that?
- Q5 Which of the three test types is the most time-consuming and expensive, and why?
- Q6 An organization buys cyber-insurance rather than reducing a risk itself. Which of the four risk responses is that?

Answers in the speaker notes, and in the answer key at the end of the deck.



Contract documents

03



Five documents before testing

DOCUMENT	ANSWERS	PROTECTS AGAINST
Scope of Work	Who, what, when, where and why	Testing the wrong system; unpaid extra work
Rules of Engagement	How the test will be carried out	Mishandled data; unannounced incidents
Master Service Agreement	Terms governing repeat business	Renegotiating every engagement
Non-Disclosure Agreement	What may be shared, and with whom	Disclosure of findings
Permission to Test	Whether the tester is authorized	Being treated as an intruder

Inside the Scope of Work

What is being tested — IP ranges, servers, applications, network devices and resources, listed explicitly.

Off-limits areas — any system or feature not to be tested; accessing these is unauthorized.

Time frame, and the deliverables: which reports arrive, and when.

Legal jurisdiction — which state's laws apply when the parties are in different locations.

Test goal, such as compliance, and the acceptable end results.

Special considerations — travel, certifications, anything unexpected — and payment terms.

Signatures from each organization once the document is final.

Inside the Rules of Engagement

Environment type

White box for a known environment, gray box for a partially known one, black box where the tester has no prior knowledge.

Sensitive data handling

The procedures for managing and protecting confidential data discovered during the test.

Notification procedures

The protocol for notifying the IT team in the event of an incident, or whenever communication is needed.

“Often called the get out of jail free card.”

— Permission to Test, used as a last resort when the tester is stopped by client personnel who are unaware of the assessment; it explains that the actions are authorized and part of an approved engagement.

Check your understanding

- Q7 Which document defines how the test will be carried out, and which defines what will be tested?
- Q8 Which document is called the “get out of jail free card,” and when is it produced?

Answers in the speaker notes, and in the answer key at the end of the deck.



Threat actors and the law

04



Categories of hackers

CATEGORY	DEFINING BEHAVIOUR
White hat	Skilled; uses the knowledge defensively, on authorized systems. The ethical hacker.
Black hat	Also called a cracker. Skilled; uses the knowledge for illegal or malicious ends such as denial of service and identity theft.
Grey hat	Between the two. May cross ethical lines without permission but typically means well — informing an owner of a vulnerability found.

Categories of hackers, continued

CATEGORY	DEFINING BEHAVIOUR
Suicide hacker	Concerned only with taking the target down for a cause, disregarding personal consequences.
Cyber terrorist	Motivated by religious or political belief; aims at severe disruption or widespread fear.
State-sponsored hacker	Works for a government to obtain top-secret information from other governments.
Hacktivist	Protests an event or situation to draw attention to a view — defacing websites, denial of service.
Script kiddie	Extremely unskilled; runs tools and scripts written by others without understanding them.

Hacker motivations

Greed, blackmail and revenge — the common motivations for black hats.

Political or religious belief, and terrorism.

Recognition earned by a successful attack.

Curiosity: the desire to take things apart, learn how they work, reverse engineer them — the motivation that leads people into ethical hacking.

Ethical hacker skills

Technical

A computer expert, with in-depth knowledge of operating systems and of networking concepts.

Non-technical

The ability to learn, a strong work ethic, and awareness of local standards and laws.

Advanced persistent threats

A stealthy network attack in which a person or group gains unauthorized access and remains undetected for an extended period.

The access is repeated: the attacker returns to the system over time.

Often attributed to nation-states or large organizations, though others can carry them out.

2010

The Stuxnet worm targeted Iranian industrial infrastructure, reaching the programmable logic controllers by USB drive even though the systems were not connected to the internet.

Threat modeling: five questions

- 01 What do I have that is worth protecting?
- 02 Who do I want to protect it from?
- 03 How likely is it that I will need to protect it?
- 04 How bad are the consequences if I fail?
- 05 How much trouble am I willing to go through to prevent them?

The Electronic Frontier Foundation's five questions. Threat modeling analyses an organization's security to determine where the holes are, and produces an efficient penetration testing plan.

Federal law: Title 18, chapter 47

Section 1029

Addresses fraud related to access devices — the applications and hardware used to generate credentials.

Section 1030

Addresses fraud and related computer activity, including unauthorized access and exceeding authorized access.

“Unauthorized” and “exceeds authorized access” are the critical terms. Industry-specific regulations apply on top of these, and legal counsel should confirm all applicable local and federal law before testing begins.

Cloud and third-party systems

Cloud providers must authorize the penetration test and approve the Scope of Work.

Failing to obtain that approval can make the tester liable for unauthorized access.

Accidentally scanning a supply chain partner's network is illegal and carries liability.

Pen testers adhere strictly to the SOW and avoid touching networks outside it.

A vulnerability affecting a third party is reported to the client; client authorization is required before reporting it to that third party.

The exception: evidence of illegal activity may be reported to the appropriate authorities.

Corporate policies to review

POLICY	WHAT IT DEFINES
Password	Character count, character types, and how often passwords change.
Update frequency	The schedule for applying security patches, balancing security against operational impact.
Sensitive data handling	Access, security and breach response for PII, financial, health and credit card data — role-based access, encryption, a response plan.
Bring your own device	Usage, network access and the security risks of personal devices, including access levels and remote wipe at termination.
Computer usage	That all computer use is monitored and subject to review — no expectation of privacy on the organization’s network, which can extend to BYOD.

Handling sensitive data and disclosure

Keep financial, customer, password, health and credit card information strictly confidential.

Access only the minimum data required for reporting, and avoid taking data off-site for analysis unless it is absolutely necessary.

Vulnerability analysis can be conducted without directly accessing patient data — under HIPAA, data must not be opened or viewed.

Findings are confidential and go only to the approved client point of contact; never discuss client results in a sales pitch.

Employee misconduct or unauthorized data found during the test is reported to the client's point of contact.

When in doubt, adhere to the SOW and the ROE — that is where the tester's legal protection lives.

Check your understanding

- Q9 Which two sections of US Code Title 18 apply to hacking, and which two terms are central to them?
- Q10 You find a vulnerability that affects a supply chain partner. Who do you report it to, and who reports it onward?

Answers in the speaker notes, and in the answer key that follows.

Answer key, questions 1 to 5

ANSWER

- | | |
|----|---|
| Q1 | Reconnaissance, scanning and enumeration, gaining access, maintaining access, clearing tracks. |
| Q2 | Phase five: clearing tracks becomes reporting — a detailed record of tests performed and discoveries made. |
| Q3 | The purple team mixes red and blue, making offensive and defensive security collaborate. |
| Q4 | A gray box test — partial information, simulating an insider threat. |
| Q5 | Black box: no information is given, so extensive reconnaissance and scanning make it the most time-consuming and expensive. |
-

Answer key, questions 6 to 10

ANSWER

Q6	Transference — the risk is moved to another entity, in this case an insurer.
Q7	The Rules of Engagement define how; the Scope of Work defines what.
Q8	Permission to Test, produced as a last resort when client personnel unaware of the test stop the tester.
Q9	Sections 1029 and 1030; the terms are “unauthorized” and “exceeds authorized access.”
Q10	Report it to the client. Reporting onward is the client’s responsibility and needs client authorization.



Next: reconnaissance

Modules 1 and 2 established the process and its limits. The next session works phase one in depth.

Questions between sessions welcome